

Cyber Tabletop Exercise

Ransomware Impact on Retail Payment Operations

Scenario source: STIX bundle provided by the user.

1. Exercise Overview

Exercise title: Ransomware Impact on Retail Payment Operations

Exercise type: Facilitated tabletop exercise (TTX)

Audience: Executive, operational, cyber security, technology, payments, legal/compliance, communications, and business continuity stakeholders

Suggested duration: 90 minutes

Primary environment in scope: Retail payment processing environment supporting ACH, SEPA, domestic transfer, and settlement workflows

Purpose

This tabletop exercise is designed to test the organization's ability to respond to a ransomware incident affecting payment processing systems shortly before settlement deadlines. The scenario stresses operational resilience, executive decision-making, continuity planning, communications, and regulatory notification under time pressure.

2. Objectives

By the end of the exercise, participants should be able to:

- Assess and escalate a disruptive ransomware event affecting critical payment operations.
 - Coordinate technical containment while preserving evidence and maintaining incident command discipline.
 - Decide whether to isolate parts or all of the payment environment.
 - Determine when and how to activate payment continuity fallback procedures.
 - Prioritize payment flows based on business criticality, settlement obligations, customer impact, and regulatory expectations.
 - Coordinate executive, operational, legal, compliance, and communications decisions.
 - Evaluate regulator, customer, partner, and internal notification triggers.
 - Identify restoration priorities and recovery sequencing for the payment environment.
 - Capture lessons learned and improvement actions across resilience, response, and governance.
-

3. Scope and Assumptions

In Scope

- Payment operations and settlement processing
- Security operations and incident response
- Executive crisis management
- Legal, compliance, and regulatory communications
- Internal and external stakeholder communications
- Business continuity and fallback processing
- Recovery decision-making for affected infrastructure

Assumptions

- The organization has documented incident response, crisis management, and payment continuity procedures.
- The payment environment includes production servers, operations shared drives, and supporting administrative access paths.
- The security team has detected ransomware activity on payment processing servers.
- The incident occurs approximately two hours before end-of-day settlement.
- Participants should respond using current roles, responsibilities, and realistic internal processes.

Out of Scope

- Hands-on technical remediation
 - Detailed malware reverse engineering
 - Procurement or vendor contract negotiation
-

4. Rules of Engagement

- This is a no-fault learning exercise intended to improve readiness.
 - Participants should respond as they would in a real event using current processes and authorities.
 - There are no perfect answers; the focus is on decision quality, coordination, and identification of gaps.
 - Facilitators may provide additional details if discussion stalls.
 - Reasonable assumptions may be made where playbooks or facts are not yet available.
-

5. Scenario Summary

A financially motivated ransomware operator gains access to the bank's internal environment and deploys ransomware against systems supporting retail payment processing. Encryption begins affecting payment operations servers and shared operations drives shortly before settlement deadlines. Failed payment batches begin to accumulate, operational backlogs increase, and time-sensitive transfers are placed at risk.

The organization must decide whether to isolate the payment environment, activate fallback procedures, delay customer transfers, and notify regulators before settlement cut-off. The exercise is intended to surface tensions between technical containment, business continuity, customer impact, and legal or regulatory obligations.

6. Participant Roles

Executive / Crisis Management

- Executive sponsor / crisis lead
- Business line leadership for payments
- Chief Information Security Officer or delegate
- Chief Operations Officer or delegate

Operational / Business

- Head of payment operations
- Treasury / liquidity management representative
- Settlement operations lead
- Customer service / relationship management representative
- Business continuity lead

Technical / Response

- Security operations center lead
- Incident response lead
- Infrastructure / platform operations lead
- Backup and recovery lead
- Identity and access management lead

Control Functions

- Legal counsel
 - Compliance / regulatory affairs
 - Privacy office
 - Corporate communications / media relations
 - Risk management
-

7. Facilitation Guidance

Suggested Exercise Flow

- 10 minutes: Introduction, objectives, roles, and rules
- 15 minutes: Inject 1 discussion
- 20 minutes: Inject 2 discussion

- 20 minutes: Inject 3 discussion
- 15 minutes: Inject 4 discussion
- 10 minutes: Debrief and lessons learned

What Facilitators Should Watch For

- Clarity of authority for isolation and continuity decisions
 - Whether participants distinguish containment from recovery
 - Evidence preservation considerations before restoration
 - Whether communications are synchronized across technical, executive, and regulatory functions
 - Payment prioritization logic and decision ownership
 - Escalation thresholds and timing of regulator notification
-

8. Detailed Scenario Timeline and Injects

Inject 1: Operational Disruption and Confirmed Encryption Alerts

Simulated time: T-2 hours before end-of-day settlement

Inject

Payment operations reports failed payment batches and a growing processing backlog. The SOC confirms ransomware activity on payment processing servers and associated operations file shares. Several payment workflows are degraded or unavailable, and teams report they may miss settlement deadlines if the disruption continues.

What Participants Know

- Payment batches are failing in the retail payment processing environment.
- Shared operations drives used by payment teams are becoming inaccessible.
- Ransomware activity has been confirmed on payment processing servers.
- End-of-day settlement is two hours away.
- Customer transfers, domestic payments, and selected priority flows may be impacted.

Discussion Questions

- What is the immediate incident classification and who is accountable for directing response actions?
- What technical containment actions should be taken now?
- Which systems, user groups, and interfaces must be isolated immediately, and which should remain available if safe?
- What are the most critical business services and payment flows that must be prioritized?
- What criteria determine whether fallback procedures should be activated now versus later?
- What information is needed within the next 15 to 30 minutes to support executive decisions?
- Who must be informed internally at this stage?

Expected Actions

- Establish incident command and executive awareness.
- Validate the scope of encryption and likely blast radius.
- Contain affected servers and restrict lateral movement opportunities.
- Preserve logs, volatile artifacts, and forensic evidence.
- Launch a rapid business impact assessment focused on settlement and customer obligations.
- Prepare continuity and payment prioritization options for executive decision.

Facilitator Notes

Look for whether the team immediately distinguishes between impacted payment servers and broader enterprise systems. Strong responses should include rapid scoping, incident leadership, preservation of evidence, and early business impact analysis rather than immediate restoration attempts.

Inject 2: Executive Decision Point Before Settlement Cut-Off

Simulated time: T-90 minutes before settlement cut-off

Inject

Executives must decide whether to isolate the entire payment environment, activate manual fallback processes, delay customer transfers, and notify the regulator before settlement cut-off. Operations advises that some priority payments may still be completed through documented workarounds if specific dependencies remain available.

What Participants Know

- The ransomware is active in the payment zone.
- Full isolation would likely reduce further damage but may halt additional payment processing.
- Partial operations may still be possible through fallback procedures.
- Settlement deadlines are approaching quickly.
- Customer and counterparty impact will become visible soon.

Discussion Questions

- Who has authority to order full isolation of the payment environment?
- What is the threshold for switching from standard operations to continuity mode?
- Which payment types should be prioritized and why?
- Should the bank delay lower-priority customer transfers to preserve capacity for critical obligations?
- What regulatory notifications may be required before settlement cut-off?
- What should be communicated to customers, counterparties, payment partners, and internal executives?
- What legal, reputational, and operational risks arise from continued partial processing?

Expected Actions

- Make a time-bound executive decision on containment versus continuity.
- Activate manual or alternate payment processing for priority transactions if authorized.
- Implement payment triage based on business criticality, contractual obligations, regulatory requirements, and customer harm.
- Prepare regulator notification decisioning and draft key messages.
- Establish communication channels for front-line operations, relationship managers, and executive leadership.

Facilitator Notes

This phase should expose governance gaps. Participants should articulate decision rights, the basis for prioritization, and how they would balance operational continuity against the risk of further compromise.

Inject 3: Containment Stabilized, Restoration Decisions Begin

Simulated time: Several hours later

Inject

Containment measures have reduced further spread within the payment zone. However, encryption has rendered multiple payment servers and shared operational resources unavailable. The incident response team advises that restoration should not begin until evidence is preserved and recovery sequencing is approved. Some manual fallback processing has started, but backlog and customer delay pressure are increasing.

What Participants Know

- The immediate spread appears limited, but full eradication is not yet confirmed.
- Priority payments are being managed through fallback methods with reduced capacity.
- Customer delays are accumulating.
- Communications pressure is increasing from internal stakeholders and major clients.
- Recovery sequencing decisions are needed.

Discussion Questions

- What conditions must be met before restoration begins?
- How should the organization sequence recovery of payment systems, file shares, interfaces, and user access?
- How does the team validate backups and ensure restored systems are safe?
- What evidence preservation steps are mandatory before rebuilding or restoring?
- What additional notifications are required as impact becomes clearer?
- How should the organization manage media, customer, and regulator inquiries if delays become public?

Expected Actions

- Approve a restoration decision framework with technical and business sign-off.
- Prioritize recovery of systems enabling settlement, reconciliation, and payment visibility.
- Validate backup integrity and restoration safety.
- Continue fallback processing where necessary.
- Update leadership and stakeholders with realistic timelines, known impacts, and decision dependencies.

Facilitator Notes

Good answers should include restoration gates, backup validation, forensic preservation, and a clearly sequenced service recovery plan rather than a simple “restore everything” approach.

Inject 4: Recovery, Notification, and Post-Incident Management

Simulated time: Next business period

Inject

The payment environment is being restored in a controlled sequence. Critical systems are returning, but some transfers were delayed and selected customers experienced disruption. Executives must determine the scope of regulator communications, customer messaging, internal reporting, and post-incident review actions.

What Participants Know

- Core payment capabilities are returning.
- The backlog is being worked through in priority order.
- Settlement disruption was at least partially realized.
- The incident may trigger internal reporting, external notifications, and formal lessons-learned activities.

Discussion Questions

- What should be included in regulator notifications or follow-up reporting?
- How should the bank communicate with affected customers and counterparties?
- What controls or gaps most likely contributed to the incident impact?
- What immediate risk reduction measures should be implemented before normal operations fully resume?
- What metrics, decisions, and timelines should be captured in the post-incident review?

Expected Actions

- Complete stakeholder communications and regulatory reporting as required.
- Finalize business and technical recovery validation.
- Document decision timelines, impact, and escalation effectiveness.

- Launch after-action review and remediation planning.
- Track corrective actions relating to segmentation, backup readiness, continuity procedures, detection, and authority clarity.

Facilitator Notes

This final phase should draw out lessons learned, not just closure. Participants should identify specific improvements in resilience, governance, communications, and restoration readiness.

9. Decision Points Summary

Key decisions expected during the exercise include:

- Whether to isolate the full payment environment or only affected segments
 - Whether to activate payment continuity fallback procedures
 - Which payment flows to prioritize under degraded conditions
 - Whether to delay or suspend selected customer transfers
 - When to notify regulators and what preliminary facts to disclose
 - When to begin restoration and under what conditions
 - How to communicate with customers, counterparties, and the media
-

10. Business and Technical Impacts to Explore

Business Impacts

- Missed or delayed settlement deadlines
- Delayed customer transfers and complaints
- Liquidity management pressure
- Increased operational workload due to manual processing
- Reputational damage and scrutiny from partners and regulators

Technical Impacts

- Encryption of payment servers and shared drives
 - Loss of visibility into payment queues and operational status
 - Potential disruption to reconciliation and settlement support services
 - Need for containment, forensics, backup validation, and safe restoration
-

11. Success Criteria

The exercise is successful if participants can:

- Clearly identify incident leadership and decision authority

- Make timely containment and continuity decisions
 - Prioritize critical payment flows under time pressure
 - Align technical, operational, legal, and executive actions
 - Demonstrate a credible approach to regulator and stakeholder communications
 - Outline safe restoration criteria and recovery sequencing
 - Identify concrete improvements after the exercise
-

12. Debrief Questions

- What decisions were made well, and why?
 - Where were authorities, escalation paths, or accountabilities unclear?
 - Was the threshold for activating continuity procedures well understood?
 - Did participants have enough information to prioritize payments effectively?
 - Were communications timely, accurate, and appropriately coordinated?
 - Did the organization demonstrate a safe and realistic restoration approach?
 - What capabilities, playbooks, or dependencies need improvement?
-

13. Recommended Improvement Areas

Potential improvement themes include:

- Payment environment segmentation and containment readiness
 - Backup integrity validation and recovery rehearsal
 - Payment continuity playbooks and transaction prioritization criteria
 - Executive decision frameworks for cyber-disruptive events
 - Regulator notification thresholds and templates
 - Internal communications and stakeholder coordination
 - Forensic preservation and restoration gating controls
-

14. MITRE ATT&CK Mapping

The following ATT&CK tactics and techniques are reflected or plausibly exercised in this scenario narrative:

Tactics

- Initial Access
- Execution
- Persistence
- Privilege Escalation
- Defense Evasion
- Discovery
- Lateral Movement
- Impact

Relevant Techniques

- **T1486 – Data Encrypted for Impact**
Central scenario action: ransomware encrypts payment processing systems and shared drives.
- **T1490 – Inhibit System Recovery**
Often associated with ransomware operations attempting to hinder restoration or backup-based recovery.
- **T1021 – Remote Services**
Plausible for lateral movement or remote administration within the payment environment.
- **T1078 – Valid Accounts**
Plausible use of legitimate credentials to access internal banking systems before payload deployment.
- **T1087 – Account Discovery**
Plausible pre-impact discovery activity within the environment.
- **T1018 – Remote System Discovery**
Plausible discovery of payment servers and related infrastructure.
- **T1041 – Exfiltration Over C2 Channel**
Not confirmed by the provided STIX, but may be discussed as an investigative consideration if participants raise double-extortion risk.

ATT&CK Notes

The STIX bundle explicitly centers on ransomware-driven disruption of payment operations, so **Impact / T1486** is the strongest direct mapping. Other techniques above are included to support realistic tabletop discussion of how a ransomware operator may have accessed, navigated, and prepared the environment prior to encryption.

15. Appendix: STIX-to-Scenario Translation

Key STIX Elements Used

- **Target organization:** Banking organization in financial services
- **Threat actor:** Financially motivated ransomware operator
- **Infrastructure targeted:** Retail payment processing environment
- **Malware:** Enterprise ransomware payload
- **Attack pattern:** Encryption of payment operations systems to disrupt settlement
- **Incident:** Ransomware affecting retail payment operations
- **Courses of action:** Activate payment continuity fallback; contain and preserve evidence in payment zone

Design Logic

The scenario was expanded from the STIX bundle into a realistic facilitated exercise by:

- Translating the incident and notes into timed injects
 - Expanding decision pressure around settlement deadlines
 - Converting courses of action into expected participant responses
 - Adding executive, operational, technical, legal, and regulatory perspectives
 - Mapping the disruptive activity to MITRE ATT&CK for analytical closure
-

16. Optional Visuals for Final PDF Layout

Suggested visuals for a polished facilitator-ready version:

- One-page scenario timeline graphic
 - Payment operations dependency map
 - Decision log table for facilitators
 - RACI-style responsibility matrix for key decisions
 - MITRE ATT&CK summary table
-

17. Facilitator Closing Statement

This exercise is intended to help the organization evaluate whether its cyber incident response, payment continuity, crisis governance, and regulatory communication processes are sufficient to manage a ransomware event affecting time-sensitive retail payment operations. The emphasis is on practical coordination, timely executive decisions, and safe recovery under pressure.